Informe — Controles ISO 27001:2022 para la confidencialidad del DBA

Universidad Nacional de Costa Rica · Escuela de Informática

EIF402 Administración de Bases de Datos · II Ciclo 2026

Asignación: Controles ISO 27001:2022 para la confidencialidad en la administración de bases de datos

Estudiante: Joseph Elías Ulate Aguilar

Profesor: Johnny Villalobos

Fecha de entrega: 27 de octubre de 2026

1. Introducción y alcance

Este trabajo diseña, mide y documenta un marco de controles basado en el Anexo A de ISO/IEC 27001:2022 para proteger la confidencialidad de una base de datos Oracle desde el rol del administrador (DBA). El DBA es el custodio técnico de los datos, pero también la cuenta con más poder para saltarse los controles; por eso el marco limita y vigila también al propio administrador.

Objetivo. Identificar los riesgos de confidencialidad del motor, relacionarlos con las tareas críticas del DBA, seleccionar y justificar los controles ISO que los tratan, y evaluar con evidencia ejecutada el nivel de madurez actual de cada control.

Entorno. El enunciado propone Oracle 19c/21c XE. Este trabajo usa Oracle AI Database 26ai Free (versión 23.26.1) en un contenedor Docker (`oracle-eliasulate`), sobre la base enchufable `FREEPDB1`, que es la base real de trabajo del curso. Medir una base real, en lugar de una instalación vacía, permite que los hallazgos describan riesgos concretos y no supuestos.

Alcance. El trabajo cubre los seis componentes del artefacto pedidos en el enunciado: riesgos, tareas, mapeo de controles, controles observables, matriz de evaluación y batería de pruebas. La evaluación se basa en un diagnóstico de solo lectura ejecutado el 20 y el 22 de octubre de 2026. La aplicación de los controles queda planteada como plan de mejora, porque varios cambios afectan cuentas que usan otros proyectos del curso.

2. Marco teórico

2.1 Cambios de ISO/IEC 27001:2022 respecto a la versión 2013

ISO/IEC 27001 define los requisitos de un sistema de gestión de seguridad de la información (SGSI) y es la norma certificable de la familia ISO 27000. Su tercera edición se aprobó el 25 de octubre de 2022 y fue enmendada en 2024 (ISO/IEC, 2022a). El cambio más visible está en el Anexo A: los 114 controles de 2013, repartidos en 14 dominios, se reorganizaron en 93 controles agrupados en cuatro temas: organizacionales (cláusula 5, 37 controles), de personas (cláusula 6, 8), físicos (cláusula 7, 14) y tecnológicos (cláusula 8, 34).

La edición 2022 incorpora once controles nuevos. Tres de ellos son centrales para este trabajo: 8.10 Eliminación de información, 8.11 Enmascaramiento de datos y 8.12 Prevención de fuga de datos. Con ellos la norma trata la exposición de datos como un riesgo con controles propios, y no solo como consecuencia de fallas de acceso. ISO/IEC 27002:2022 acompaña a la 27001 con la guía de implementación de cada control y añade atributos para clasificarlos, por ejemplo la propiedad de seguridad que protegen (confidencialidad, integridad o disponibilidad) (ISO/IEC, 2022b).

2.2 Mínimo privilegio y separación de funciones en el rol DBA

El principio de mínimo privilegio establece que cada cuenta debe tener solo los permisos que su función necesita. La separación de funciones complementa ese principio: ninguna persona debe concentrar tareas que le permitan cometer y ocultar un abuso, como administrar la base y, a la vez, controlar la auditoría que la vigila. En ISO/IEC 27001:2022 estos principios corresponden a los controles 8.2 Derechos de acceso privilegiado y 5.3 Segregación de funciones.

Oracle aplica la separación mediante privilegios administrativos distintos para cada tarea: SYSDBA para la administración completa, SYSBACKUP para respaldos, SYSKM para las llaves de cifrado y SYSDG para Data Guard, además de los roles AUDIT_ADMIN y AUDIT_VIEWER para la auditoría (Oracle, 2026a). El rol DBA, en cambio, agrupa casi todos los privilegios del sistema. En la base analizada, la cuenta de trabajo BASES1 tiene ese rol (hallazgo H-01), que es justamente la situación que el mínimo privilegio busca evitar.

2.3 Defensa en profundidad y Zero Trust aplicado a bases de datos

La defensa en profundidad protege un activo con varias capas independientes, de modo que si una falla, otra sigue protegiendo el dato. En una base de datos esas capas son la red, la autenticación, la autorización, el cifrado y la auditoría. Por ejemplo, si alguien copia un archivo de datos, el control de acceso ya no lo protege, pero el cifrado en reposo sí.

Zero Trust lleva la idea más lejos: no se concede confianza implícita a un usuario o dispositivo por estar dentro de una red o por ser propiedad de la organización, y cada acceso se autentica y autoriza por separado (Rose et al., 2020). Aplicado a una base de datos, implica autenticar cada sesión con credenciales robustas, limitar cada cuenta al mínimo necesario, cifrar la comunicación aunque ocurra en una red interna y registrar los accesos. La base analizada acepta conexiones en todas las interfaces del equipo (hallazgo H-03), lo que contradice este enfoque.

2.4 Controles técnicos de confidencialidad

- **Transparent Data Encryption (TDE).** Cifra los datos en reposo, a nivel de columna o de tablespace, y guarda la llave maestra en un keystore separado. Protege contra el robo de archivos de datos o de respaldos, pero no contra un usuario autorizado que consulta los datos, porque estos se descifran al leerse desde la base (Oracle, 2026b).
- **Dynamic Data Masking y Data Redaction.** «Dynamic Data Masking» es el nombre que usan otros motores para ocultar datos en tiempo de consulta; en Oracle la función equivalente es Data Redaction. Oculta total o parcialmente el valor de una columna en el resultado de una consulta, justo antes de devolverlo, sin modificar el dato almacenado (Oracle, 2026c).

- **Row Level Security / Virtual Private Database (VPD).** VPD agrega de forma automática una condición a las consultas sobre una tabla para que cada usuario vea solo las filas que le corresponden. Se configura con el paquete DBMS_RLS (Oracle, 2026a).
- **TLS y cifrado de red.** Protegen los datos en tránsito entre el cliente y la base. Oracle ofrece TLS y cifrado nativo de red, que se configura en el archivo sqlnet.ora (Oracle, 2026a).

Estos controles cubren estados distintos del dato: TDE, el dato en reposo; Data Redaction y VPD, el dato en uso; y el cifrado de red, el dato en tránsito. Por eso se complementan y no se reemplazan entre sí.

2.5 Prevención de fuga de datos (DLP) y respaldos cifrados

La prevención de fuga de datos busca impedir que la información salga de su entorno autorizado. En una base de datos las vías típicas de fuga son las exportaciones masivas (por ejemplo, con Data Pump), las copias para ambientes de prueba y los respaldos. Un respaldo es una copia completa de la base: si no está cifrado, quien lo obtenga tiene todos los datos sin pasar por ningún control de acceso.

RMAN permite cifrar los respaldos en tres modos: transparente, con el keystore de TDE; por contraseña; y dual, que acepta cualquiera de los dos. Oracle recomienda el modo transparente y reserva el de contraseña para respaldos que deban trasladarse a otro servidor (Oracle, s. f.-a). Los controles ISO relacionados son 8.12 Prevención de fuga de datos y 8.13 Respaldo de la información. En la base analizada, las diez piezas de respaldo más recientes están sin cifrar (hallazgo H-05).

2.6 Registro, monitoreo y correlación (SIEM)

Sin registros no es posible detectar ni demostrar un acceso indebido. Oracle concentra la auditoría en un único rastro, la auditoría unificada, que se consulta en la vista UNIFIED_AUDIT_TRAIL. Se configura con políticas que indican qué acciones registrar y sobre qué objetos (Oracle, 2026a). Un sistema SIEM reúne eventos de varias fuentes, como la base de datos, el sistema operativo y la red, y los correlaciona para detectar patrones; por ejemplo, muchas consultas a tablas con datos personales fuera del horario habitual.

En ISO/IEC 27001:2022, el control 8.15 Registro pide producir, proteger y analizar los registros de actividad; el 8.16 Actividades de monitoreo, vigilarlos; y el 5.33 Protección de registros, resguardar los registros de la organización, entre ellos el rastro de auditoría. En la base analizada, la auditoría solo tiene las políticas que Oracle activa por defecto, y ninguna cubre las tablas con datos personales (hallazgo H-10).

2.7 Ley 8968 y su reglamento

La Ley N.º 8968, Protección de la Persona frente al Tratamiento de sus Datos Personales, del 7 de julio de 2011, garantiza el derecho de toda persona a la autodeterminación informativa sobre sus datos (artículos 1 y 4). Define los datos personales, los datos sensibles y el deber de confidencialidad (artículo 3) y reconoce los derechos de acceso, rectificación y supresión (artículo 7). Además, obliga al responsable de la base de datos a adoptar medidas técnicas y organizativas que eviten el acceso no autorizado (artículo 10) y a guardar el secreto profesional sobre los datos (artículo 11). El artículo 15 crea la Agencia de Protección de Datos de los Habitantes (PRODHAB) (Ley N.º 8968, 2011).

El reglamento, Decreto Ejecutivo N.º 37554-JP de 2012, detalla esas obligaciones. Su artículo 32 regula los protocolos mínimos de actuación, y el 34, las medidas de seguridad (Decreto Ejecutivo N.º 37554-JP, 2012). Para el DBA, la ley convierte varios controles técnicos en obligaciones legales: proteger los datos personales (artículo 10) y poder suprimirlos de forma efectiva (artículo 7). En la base analizada, las tablas PERSONAS y PERSONAS_LOG, con nombres y salarios, se borraron pero siguen recuperables en la papelera (hallazgo H-07), lo que impide asegurar una supresión real.

3. Metodología

El trabajo sigue el ciclo PHVA (Planificar, Hacer, Verificar, Actuar) que pide el enunciado.

Fase	Qué se hizo	Resultado
Planificar	Identificar riesgos, mapear tareas del DBA, seleccionar y justificar controles ISO, definir controles observables y la escala de madurez	Componentes 1 a 4 del artefacto
Hacer	Escribir el diagnóstico de solo lectura y la batería de 17 pruebas con sus scripts	`diagnostico_confidencialidad.sql`, `demostracion_diagnostico.ps1` y componente 6
Verificar	Ejecutar el diagnóstico sobre la base real y asignar el nivel de cada fila de la matriz según la evidencia	Matriz de evaluación (componente 5) y 13 hallazgos
Actuar	Ordenar las correcciones por prioridad y vincular cada una con la prueba que la comprueba	Plan de mejora (sección 5)

Diagnóstico. Es un script SQL de solo lectura con 18 bloques (D00 a D17). Consulta el diccionario de datos de Oracle: cuentas y perfiles, privilegios y roles, cifrado, políticas de redacción y VPD, auditoría, respaldos, papelera y parches. Se ejecuta como SYSDBA dentro del contenedor, primero en CDB$ROOT y luego en FREEPDB1, y se complementa con la revisión de los puertos publicados por Docker, el estado del listener y el archivo sqlnet.ora. Al ser de solo lectura, no modifica la base y puede repetirse cuando se quiera.

Reproducibilidad. El diagnóstico se ejecutó el 20 de octubre de 2026 y se repitió el 22 de octubre con `demostracion_diagnostico.ps1`, que guarda cada corrida en una carpeta con fecha. Las dos salidas solo difieren en la fecha y hora de ejecución.

Escala de madurez. El enunciado pide una escala de 0 a 4, pero no la define. Se usó la siguiente definición propia:

Nivel	Nombre	Criterio	Estado
0	Inexistente	Nada trata el riesgo	No cumple
1	Inicial	Algo existe, por defecto o a medias, sin diseño del DBA	No cumple

Nivel	Nombre	Criterio	Estado
2	Diseñado	Definido y documentado; implementación parcial o sin probar	Parcial
3	Implementado y verificado	Configurado, y una prueba demuestra que funciona	Cumple
4	Gestionado	Además se revisa o monitorea periódicamente	Cumple

Ninguna fila puede recibir Cumple sin una evidencia ejecutada que lo respalde.

4. Resultados

Las 18 filas de la matriz de evaluación están en No cumple: 6 en nivel 0 y 12 en nivel 1. La base funciona con la configuración de fábrica de Oracle y no tiene controles de confidencialidad configurados a propósito. El detalle completo de los seis componentes está en el artefacto interactivo.

4.1 Riesgos de confidencialidad

La probabilidad (P) y el impacto (I) se valoran de 1 a 5, y el nivel es P × I: bajo de 1 a 6, medio de 8 a 12 y alto de 15 a 25.

ID	Riesgo	P	I	Nivel
R-CONF-01	Un usuario o un operador lee datos personales que no necesita, por privilegios excesivos	4	5	20, alto
R-CONF-02	Un tercero entra con una contraseña débil, por defecto o adivinada	3	5	15, alto
R-CONF-03	Alguien con acceso a los archivos o a un respaldo lee los datos sin pasar por la base	3	5	15, alto
R-CONF-04	Datos personales reales terminan en un clon de prueba o en una exportación	3	4	12, medio
R-CONF-05	La comunicación viaja sin cifrar o el puerto queda expuesto a otras máquinas	4	4	16, alto

4.2 Hallazgos principales

El diagnóstico produjo 13 hallazgos, 6 de gravedad alta. Entre paréntesis se indica el bloque de evidencia que los respalda.

ID	Hallazgo	Control
H-01	La cuenta BASES1, que usan los proyectos del curso, tiene el rol DBA (D09)	A8.2, A5.18
H-02	La tabla CONEXION_ORACLE guarda contraseñas de conexión a otras	A5.17

ID	Hallazgo	Control
	bases (D11)	
H-03	Los puertos 1521 y 5500 aceptan conexiones de cualquier equipo de la red, y sqlnet.ora no tiene cifrado (D-red)	A8.20
H-04	No hay TDE: keystore no disponible y 0 de 12 tablespaces cifrados (D02, D12)	A8.12
H-05	Las 10 piezas de respaldo RMAN más recientes están sin cifrar (D03)	A8.13
H-06	No hay políticas de Data Redaction ni de VPD; salarios, correos y contraseñas se leen completos (D11, D13)	A8.11, A8.3

Los otros siete hallazgos, de gravedad media, se refieren a la papelera, las reglas de contraseñas, el formato de contraseña 11G, la auditoría, la clasificación de columnas, la versión del motor y la base FREEPDB2 sin revisar.

4.3 Fortalezas

El diagnóstico también confirmó controles que ya funcionan:

- Solo SYS tiene el privilegio SYSDBA (D01).
- Ninguna cuenta usa una contraseña de fábrica (D06).
- Ninguna cuenta propia tiene privilegios ANY otorgados directamente (D08).
- No hay permisos entre esquemas ni a PUBLIC (D10).
- La auditoría unificada está activa (D04).
- La base funciona en modo ARCHIVELOG (D00).

5. Plan de mejora

El plan tiene 13 acciones, una por hallazgo. Las seis primeras son de prioridad alta. Cada acción se comprueba con una prueba de la batería; al pasarla, las filas de la matriz relacionadas pueden subir a nivel 3 (Cumple).

#	Acción	Hallazgo	Se comprueba con
1	Quitar el rol DBA a BASES1 y darle un rol con solo los permisos que usan sus aplicaciones	H-01	PT-01, PT-02
2	Revisar el formato de las contraseñas de CONEXION_ORACLE y cifrarlas si se pueden leer	H-02	V-01
3	Publicar los puertos solo en 127.0.0.1 y activar el cifrado de red	H-03	PT-12, V-03
4	Crear el keystore y cifrar con TDE los tablespaces con datos personales	H-04	PT-06

#	Acción	Hallazgo	Se comprueba con
5	Cifrar los respaldos RMAN y probar su restauración	H-05	PT-13
6	Ocultar SALARIO, EMAIL y PASSWORD con Data Redaction y filtrar filas con VPD	H-06	PT-07, PT-08
7	Purgar la papelera y definir un procedimiento de supresión de datos	H-07	PT-14
8	Crear un perfil de contraseñas robusto y bloquear las cuentas sin uso	H-08	PT-04, PT-05
9	Aceptar solo el formato de contraseña 12C	H-09	PT-04
10	Auditar el acceso a tablas con datos personales y separar el rol de auditor	H-10	PT-09, PT-10
11	Clasificar las 19 columnas sensibles	H-11	PT-15
12	Actualizar Oracle a la versión 23.26.3, la vigente según Oracle (s. f.-b)	H-12	PT-11
13	Diagnosticar FREEPDB2 y enmascarar o eliminar sus datos si es una copia	H-13	V-02, PT-16

Las pruebas PT trabajan sobre un esquema de demostración (APP_OWNER) con datos ficticios. Los cambios sobre cuentas y tablas reales deben coordinarse con los otros proyectos del curso que usan BASES1 y GESTOR_RMAN, y requieren un respaldo previo.

6. Conclusiones

- **La base está expuesta en todos los estados del dato.** Los datos en reposo, en respaldo, en tránsito y en consulta carecen de protección específica. Las 18 filas de la matriz están en No cumple.
- **El riesgo más grave es el exceso de privilegios.** Una cuenta de trabajo con el rol DBA anula buena parte de los demás controles, porque puede leer, exportar y modificar todo. Por eso es la primera acción del plan.
- **La configuración por defecto no basta.** Oracle trae algunas protecciones activas, como la auditoría unificada y el corte tras intentos fallidos por conexión, pero ninguna diseñada para los datos personales de esta base.
- **La evidencia ejecutada permite evaluar con honestidad.** Cada nivel de la matriz cita el bloque del diagnóstico que lo respalda, y el diagnóstico se puede repetir para medir el efecto de cada mejora.
- **La Ley 8968 convierte estos controles en obligaciones.** Proteger los datos personales y poder suprimirlos de forma efectiva no es solo una buena práctica, sino un deber del responsable de la base de datos.

7. Uso de inteligencia artificial

En este trabajo se usó una sola herramienta de IA generativa, Claude, modelo Opus 5.5 (Anthropic, 2026), entre el 20 y el 27 de octubre de 2026. La tabla registra cada solicitud en el orden en que se hizo. Los prompts se transcriben tal como se escribieron; el prompt 1, por su extensión, está completo en el Anexo A.

#	Herramienta IA	Prompt exacto utilizado	Aporte de la IA	Validación / Corrección del estudiante
1	Claude (Opus 5.5)	«Quiero que actúes como un analista de requisitos académicos y asesor técnico…» (texto completo en el Anexo A)	Guía de análisis del enunciado: tabla de 26 requisitos, propuesta de escala 0-4, relación entre tareas y controles, borradores de scripts	Señalé que el entorno sería Docker 26ai Free y no el 21c XE del laboratorio, y la guía se ajustó.
2	Claude (Opus 5.5)	«Para la elaboración de este entrgable sí la voy a hacen en mi docker, además dame la parte del Producto Esperado - El Artefacto, para ver si hacemos para ver si se crea de una buena manera»	Artefacto HTML con los seis componentes: 5 riesgos, 12 tareas, mapeo de 15 controles, 15 observables, matriz y 17 pruebas con scripts	
3	Claude (Opus 5.5)	«Estaba viendo el HTML y veo que eel plan está sin ejecutar, cómo le hago para ponerlo afuncionar y que de un análisis correcto a mi base de datos?»	Script de diagnóstico de solo lectura (D00-D17), comandos de PowerShell y, a partir de la salida, los 13 hallazgos y los	Ejecuté el diagnóstico en mi contenedor el 20 de octubre y entregué las salidas reales; los niveles salen de esa evidencia y no de

#	Herramienta IA	Prompt exacto utilizado	Aporte de la IA	Validación / Corrección del estudiante
			niveles de la matriz	suposiciones.
4	Claude (Opus 5.5)	«Podemos hacer que desde el html exista un botón para que se haga el análisis o eso está fuera de lo solicitado del proyecto o es algo que no tiene sentido agregar?»	Explicación de por qué un botón de análisis en vivo no conviene: requiere guardar credenciales privilegiadas	Decidí no agregar el botón
5	Claude (Opus 5.5)	«no, no quiero que quede como un avance, solo quería modificar un poco la estructura del html que sea un poco más amigable porque hay mucho texto técnico que no entiendo, mantenga la base del antiguo html pero más fácil de interpretar»	Versión del artefacto con explicaciones en lenguaje sencillo, guía de códigos y glosario	Rechacé una versión intermedia con formato de reporte de avance y pedí volver a la estructura original
6	Claude (Opus 5.5)	«me puedes pasar los comandos y el script utilizado por si el profesor me pide una demostración»	Script `demostracion_diagnostico.ps1`	Al ejecutarlo, la primera corrida dio una salida vacía porque la base no había terminado de abrir; se corrigió el script para esperar a que abra. La segunda corrida, del 22 de octubre, dio los mismos resultados que la

#	Herramienta IA	Prompt exacto utilizado	Aporte de la IA	Validación / Corrección del estudiante
				del 20

Nombre: Joseph Elías Ulate Aguilar

Fecha: __27__ de ____octubre____ de 2026

8. Declaración jurada

Yo, Joseph Elías Ulate Aguilar, declaro que todo contenido generado con IA ha sido declarado en la tabla anterior, validado contra fuentes oficiales (ISO, documentación del motor de BD) y que asumo responsabilidad por su veracidad. Entiendo que omitir esta declaración constituye falta grave.

Fecha: _27_ de ____octubre____ de 2026

9. Referencias

Anthropic. (2026). *Claude* (versión Opus 5.5) [Modelo de lenguaje de gran tamaño]. https://claude.ai

Decreto Ejecutivo N.º 37554-JP. (2012, 30 de octubre). *Reglamento a la Ley de Protección de la Persona frente al Tratamiento de sus Datos Personales*. Alcance Digital N.º 42 a La Gaceta N.º 45, 5 de marzo de 2013. https://www.tse.go.cr/pdf/normativa/reglamentoleyproteccionpersona.pdf

International Organization for Standardization e International Electrotechnical Commission. (2022a). *Information security, cybersecurity and privacy protection — Information security management systems — Requirements* (ISO/IEC 27001:2022, 3.ª ed.).

International Organization for Standardization e International Electrotechnical Commission. (2022b). *Information security, cybersecurity and privacy protection — Information security controls* (ISO/IEC 27002:2022).

Ley N.º 8968. (2011, 7 de julio). *Ley de Protección de la Persona frente al Tratamiento de sus Datos Personales*. Asamblea Legislativa de la República de Costa Rica. https://www.sutel.go.cr/sites/default/files/normativas/ley_proteccion_de_la_persona_frente_al_tratamiento_de_sus_ley_8968.pdf

Oracle. (s. f.-a). *Oracle AI Database backup and recovery reference, release 19* (E96242-15). Recuperado el 27 de octubre de 2026, de https://docs.oracle.com/en/database/oracle/oracle-database/19/rcmrf/SET.html

Oracle. (s. f.-b). *Oracle Database Free: Download*. Recuperado el 20 de octubre de 2026, de https://www.oracle.com/database/free/download

Oracle. (2026a). *Oracle Database security guide, release 26* (G43025-10). https://docs.oracle.com/en/database/oracle/oracle-database/26/dbseg/

Oracle. (2026b). *Oracle AI Database transparent data encryption guide, release 26ai* (G43027-06). https://docs.oracle.com/en/database/oracle/oracle-database/26/dbtde/

Oracle. (2026c). *Oracle Database data redaction guide, release 26* (G43026-03). https://docs.oracle.com/en/database/oracle/oracle-database/26/dbred/

Rose, S., Borchert, O., Mitchell, S. y Connelly, S. (2020). *Zero trust architecture* (NIST Special Publication 800-207). National Institute of Standards and Technology. https://doi.org/10.6028/NIST.SP.800-207

Anexo A. Prompt 1 completo

Texto exacto enviado a Claude el 20 de octubre de 2026, junto con el PDF del enunciado.

```
Quiero que actúes como un **analista de requisitos académicos y asesor técnico
especializado en Administración de Bases de Datos, seguridad de la información e
ISO/IEC 27001:2022 e ISO/IEC 27002:2022**.

Te voy a proporcionar un PDF que contiene una asignación universitaria del curso
Administración de Bases de Datos de la Universidad Nacional de Costa Rica (UNA).

Tu tarea principal es **leer y analizar el documento completo para comprender
exactamente qué solicita el profesor**, cuáles son los requisitos obligatorios, cómo
se deben desarrollar y qué debo entregar para cumplir con la asignación y obtener la
mejor calificación posible según la rúbrica.

No quiero que te limites a hacer un resumen. Necesito que conviertas las
instrucciones del profesor en una guía clara, ordenada y práctica para desarrollar el
proyecto.

### 1. Análisis general de la asignación

Primero, explícame con palabras sencillas:

- ¿Cuál es el propósito principal del proyecto?
- ¿Qué problema de seguridad debemos resolver?
- ¿Cuál es el papel del Administrador de Bases de Datos (DBA)?
- ¿Qué relación tienen ISO 27001:2022 e ISO 27002:2022 con el proyecto?
- ¿Qué significa proteger la confidencialidad de una base de datos en este contexto?
- ¿Qué resultado final espera recibir el profesor?

Explícamelo como a un estudiante universitario que conoce conceptos básicos de bases
de datos, pero que necesita orientación para comprender el alcance completo del
trabajo.

### 2. Extracción de todos los requisitos

Lee todas las páginas del PDF e identifica cada requisito solicitado por el profesor.

Organízalos en una tabla con las siguientes columnas:

- ID del requisito.
```

- Requisito solicitado.
- Descripción de lo que se debe realizar.
- Producto o evidencia que demuestra su cumplimiento.
- Prioridad: obligatorio, complementario o no especificado.
- Sección o página del documento donde aparece.

No omitas requisitos pequeños, instrucciones metodológicas, herramientas, documentación, scripts, presentaciones ni declaraciones obligatorias.

Distingue claramente entre lo que el profesor exige expresamente y lo que tú recomiendas para mejorar el proyecto.

3. Explicación de cada producto esperado

Desglosa y explica individualmente los seis componentes del artefacto que aparecen en la sección «Producto Esperado»:

1. Tabla de riesgos de confidencialidad R-CONF-01 a R-CONF-05, incluyendo impacto y probabilidad.
2. Tabla de tareas críticas del DBA.
3. Mapeo de controles ISO, implementación sugerida y evidencia observable.
4. Lista de 15 controles observables por un auditor externo.
5. Matriz de evaluación con las columnas Tarea, Riesgo, Control, Criterio 0-4, Evidencia y Estado.
6. Batería de pruebas con ID, tipo, procedimiento, resultado esperado y herramienta.

Para cada componente, explícame:

- Qué significa.
- Para qué sirve.
- Qué información debe incluir.
- Cómo se relaciona con los otros componentes.
- Qué debería contener un resultado correctamente desarrollado.
- Qué errores debo evitar.

Incluye ejemplos pequeños cuando ayuden a comprender el requisito, pero identifica los ejemplos como ilustrativos y no como resultados definitivos del proyecto.

4. Marco teórico e investigación

Identifica todos los temas que el profesor solicita investigar y sintetizar en 2-3 páginas:

- Cambios de ISO 27001:2022 respecto a la versión 2013.
- Principio de mínimo privilegio y separación de funciones en el rol DBA.
- Defensa en profundidad y Zero Trust aplicado a bases de datos.
- TDE, Dynamic Data Masking, Data Redaction, Row Level Security/VPD y TLS.
- Prevención de fuga de datos (DLP) y respaldos cifrados.
- Logging, monitoreo y correlación mediante SIEM.
- Ley 8968 de Costa Rica y su reglamento.

Explícame qué debo investigar sobre cada tema y cómo relacionarlo con la confidencialidad de las bases de datos.

Respeta la extensión indicada por el profesor y no inventes citas bibliográficas. Si

utilizas fuentes externas, identifica las fuentes oficiales y proporciona enlaces verificables.

5. Controles ISO y tareas del DBA

Analiza los controles mencionados expresamente en la asignación:

A5.12, A5.15, A5.16, A5.17, A5.18, A5.33, A8.2, A8.3, A8.5, A8.10, A8.11, A8.12, A8.13, A8.15 y A8.20.

Explícame qué papel cumplen en el proyecto y cómo deberían relacionarse con las tareas del DBA y los riesgos de confidencialidad.

También identifica las tareas críticas que menciona el profesor, incluyendo gestión de usuarios y privilegios, autenticación, cifrado TDE, masking, backups, auditoría, parcheo, listener, eliminación segura de datos, logs y clones DEV/TEST.

Importante: no asumas que todos los controles se aplican de la misma manera a todas las tareas. Justifica cada relación con base en la documentación oficial y el contexto de Oracle.

6. Matriz de evaluación y escala de madurez

Explícame cómo interpretar la escala de madurez de 0 a 4 solicitada por el profesor.

Propón una interpretación inicial de cada nivel, pero aclara que es una propuesta de trabajo y no una definición oficial del documento si este no la especifica.

Explica la diferencia entre:

- Un control diseñado.
- Un control implementado.
- Un control que funciona correctamente.
- Un control que cuenta con evidencia verificable.
- Los estados Cumple, No cumple y Parcial.

Indica cómo se debería evaluar cada control sin asignar puntuaciones arbitrarias ni declarar cumplimientos que no se hayan demostrado.

7. Pruebas técnicas y scripts SQL

El profesor exige pruebas técnicas y scripts de verificación, utilizando Oracle 19c/21c XE y SQL Developer como herramientas propuestas.

Explícame qué debe contener cada prueba y cómo demostrar que los controles funcionan.

Para cada prueba que recomiendes, identifica:

- ID.
- Riesgo que se pretende mitigar.
- Control ISO relacionado.
- Objetivo.
- Procedimiento.
- Consulta SQL o script de verificación.
- Resultado esperado.

- Evidencia que debe guardarse.
- Herramienta necesaria.

Ten en cuenta que el entorno indicado es Oracle. No utilices consultas de PostgreSQL o MySQL como si fueran compatibles con Oracle.

Diferencia los ejemplos ilustrativos de los scripts que realmente podrían ejecutarse. Si una prueba requiere privilegios administrativos, configuración adicional, datos de ejemplo o funciones que no están disponibles en Oracle XE, indícalo expresamente.

No afirmes que una prueba fue ejecutada ni que un control cumple si no existe evidencia real.

8. Artefacto final y posible sitio web

El documento permite entregar un artefacto interactivo en HTML, PDF o sitio web.

Explícame cómo podría organizar el contenido para que cumpla con todos los requisitos del profesor, incluyendo las tablas, las matrices, las pruebas, las evidencias y los controles observables.

Si propusieras una estructura de sitio web, organiza sus secciones y explica qué contenido debería aparecer en cada una.

No asumas que el profesor exige una tecnología específica para desarrollar el sitio, ya que debes distinguir las herramientas expresamente indicadas de las decisiones técnicas que todavía podemos tomar.

9. Rúbrica y estrategia para obtener una buena calificación

Analiza los criterios de evaluación y sus porcentajes:

- Identificación de riesgos y tareas DBA: 20%.
- Mapeo y justificación de controles ISO: 20%.
- Matriz de evaluación y controles observables: 20%.
- Pruebas técnicas y scripts: 15%.
- Documentación de uso de IA y referencias APA 7: 15%.
- Presentación, video y repositorio: 10%.

Para cada criterio, explica qué evidencias concretas debería incluir el proyecto para demostrar que está bien desarrollado.

Después, crea una lista de verificación que pueda utilizar antes de entregar el trabajo.

10. Entregables y aspectos administrativos

Extrae y explica todos los entregables finales:

- Informe PDF con el artefacto o enlace al artefacto interactivo.
- Scripts SQL de verificación.
- Repositorio Git.
- Video explicativo de cinco minutos.
- Tabla de uso de IA firmada.
- Declaración jurada indicada en el documento.

- Referencias bibliográficas en formato APA 7.

Indica cuáles son obligatorios, qué deberían contener y qué aspectos debo verificar antes de la entrega.

11. Uso ético de inteligencia artificial

Explica las instrucciones del profesor para documentar el uso de IA.

Prepara un ejemplo de cómo completar la tabla con estas columnas:

- Herramienta de IA.
- Prompt exacto utilizado.
- Aporte de la IA.
- Validación o corrección del estudiante.
- Fuente verificada.

El ejemplo debe dejar claro que debo registrar los prompts que realmente utilice, revisar las respuestas y verificar las fuentes. No inventes prompts supuestamente utilizados ni presentes verificaciones que todavía no he realizado.

Explica también qué debo revisar antes de firmar la declaración jurada.

12. Plan de trabajo paso a paso

Finalmente, transforma todo el análisis en un plan de ejecución ordenado por etapas, desde la comprensión de la asignación hasta la entrega final.

Para cada etapa, indica:

- Objetivo.
- Actividades.
- Resultado que debe quedar terminado.
- Dependencias respecto a etapas anteriores.
- Cómo comprobar que está lista.

Organiza las actividades de manera que primero se definan los riesgos, luego las tareas del DBA, los controles, las matrices, las pruebas, la implementación del artefacto y, finalmente, la documentación y presentación.

Reglas que debes respetar durante todo el análisis

1. Lee las tres páginas completas del documento antes de responder.
2. Utiliza el PDF como fuente principal para determinar qué solicita el profesor.
3. No confundas requisitos expresos con recomendaciones tuyas.
4. No omitas ningún requisito obligatorio.
5. No inventes instrucciones, fechas de entrega, tecnologías obligatorias, criterios de evaluación ni evidencias.
6. Si falta información, indícalo claramente y formula una recomendación separada.
7. Cuando un dato técnico de ISO u Oracle requiera verificación externa, consulta fuentes oficiales y proporciona referencias verificables.
8. Mantén la terminología del profesor, pero explica los conceptos con lenguaje claro y ejemplos prácticos.
9. Evita desarrollar todo el proyecto de una sola vez sin explicar su estructura. Primero quiero comprender el alcance y contar con un plan de trabajo.

10. Si la respuesta es demasiado extensa, divídela en secciones sin omitir requisitos.

Resultado que espero: un análisis completo, preciso y práctico de la asignación que me permita entender qué tengo que hacer, por qué debo hacerlo, cómo se relacionan los componentes y cómo comprobar que he cumplido con todo lo que solicita el profesor.

Al terminar, incluye una sección titulada «Resumen de lo que el profesor realmente quiere» con una explicación breve y una lista de los elementos que no puedo dejar por fuera.